

Essential Infosec Terminology

- **Threat** : A threat is a malicious actor whose objective is to breach, cause damage, steal or exfiltrate data from network or system. Threats usually target assets.
- **Assets**: Assets are typically business or service critical systems on a company network that store data, provide services to clients or are integral to the running of the company. As a result, assets are attractive to attackers.
 - Assets can also be employees.
 - During risk assessments/ vulnerability assessments, assets need to be identified.
- **Risk**: Is the potential impact that a threat or vulnerability will/can have to an organization. Risk is used to determine the probability of a potential vulnerability occurring and its consequent affect.
- **Vulnerability**: A vulnerability is a weakness or flaw in a system or network that when exploited, will compromise the integrity and security of the system or network and can lead to unauthorized access.
- **Exploit**: An exploit is the process of breaking in to a system or network through a set of or a particular vulnerability. It utilizes a payload to perform specific malicious tasks.
- **Payload**: A payload is a chunk of exploit code whose purpose is to perform specific tasks on the target system or network, for example: destroy and exfiltrate data, setup backdoor access etc.
- **0-Day**: A Zero-Day-vulnerability is a system or network that has not yet been patched by the developer.
- **Confidentiality**: This ensures that data is accessible to only those that have authorized access. Example: encryption of data to prevent unauthorized access.
- **Integrity**: This ensures that the integrity of the data is maintained and that no unauthorized changes have been made to the data. Example: MD5 signature hashing or checksum.

- **Availability:** This ensures that the systems that store and process data are accessible to authorized users when needed. Example: DDOS protection.
- **Authenticity:** This is used to ensure the authenticity of communication or transfer of data as being genuine. Example : 2FA, Biometrics etc..
- **Non-Repudiation:** This is used to ensure that communication between sender and receiver cannot be refuted.
- **Disclosure attacks** seek to gain unauthorized access to information or systems.
- **Alteration attacks** seek to make unauthorized changes to information or systems.
- **Denial attacks** seek to prevent legitimate use of information and systems.
- **Penetration Testing:** penetration testing is the process of simulating an attack on a network or system to evaluate the security posture of the system and identify vulnerabilities that can be exploited. This is achieved by simulating various types of attacks on the target network or host.
- The main objective of a pentest is to identify vulnerabilities and document how they can be exploited (POC).
- Penetration testing requires written permission and authorization from the management/top down authorization model.
- The agreement between an organization and a penetration tester should include the following:
 - Scope – What to test.
 - Timeframe – When to test, and how long the test will take.
- **Importance of penetration testing:**
 - Testing security controls & policies.
 - Identifying threats & Vulnerabilities.
 - Compliance and regulation testing & maintenance.
 - Testing security infrastructure, firewalls, WAF
 - Testing new hardware, software or organizational infrastructure.
- **Blue Team:** Is a defense team responsible for performing vulnerability assessments and security audits on the company assets and digital

infrastructure to identify vulnerabilities and test the effectiveness of security controls. Their primary objective is to defend against attacks and to predict and prevent future ones.

- **Red Team:** Is a offensive team that simulates attacks on the assets and digital infrastructure of an organization to test the overall security posture and to identify weaknesses and vulnerabilities that can be exploited.
- **Black Hat Hackers.**
- **White Hat Hackers.**
- **Grey Hat Hackers.**
- **Suicide Hackers.**
- **Script Kiddies.**
- **Cyber Terrorists.**
- **Hacktivist.**
- **Black-Box-testing:** Is testing that involves zero knowledge or information about organizations digital infrastructure and or assets. This test is used to assess the overall security posture of an organization, from publicly available information to misconfigurations and social engineering. Black-box testing simulates a real attack scenario and as a result is extremely comprehensive and granular.
- **White-Box-testing:** In this test the complete digital infrastructure and assets are disclosed to the penetration tester and is primarily used by organizations to test specific sections/areas or to perform a complete security audit.
- **Grey-Box-testing:** Involves combining both white and black box testing to simulate attacks from both insiders and outsiders (external threats) . Note: some knowledge of the digital infrastructure is disclosed, not all.
- **Penetration Testing Phases:**
 - Pre-Engagement Interactions.
 - Reconnaissance or OSINT.
 - Threat Modeling & Vulnerability Identification.
 - Exploitation.
 - Post-Exploitation, Analysis, Recommendations.

- Reporting.
- **Penetration testing methodologies:** A penetration testing methodology is a comprehensive methodical approach that is used in penetration testing to identify vulnerability and weakness in the overall security posture of an organization.
 - **Advantages:**
 - Clear methodical and systematic approach to testing.
 - Ensures that tests are reliable, accurate and consistent across the board.
- **Note:** Pentesting methodologies need to be extremely comprehensive and accurate to ensure that a penetration test is performed successfully. (A penetration test is only as comprehensive as the methodology that was used.)
- Both proprietary and open source methodologies exist.
 - **OSSTMM:** Open Source Security Testing methodology.
 - **OWASP:** Open Web Application Security Project.
- **The Cyber Kill Chain:**
 - Reconnaissance.
 - Weaponization.
 - Delivery.
 - Exploitation.
 - Installation.
 - Command and Control.
 - Action on objective.
- **The Common Vulnerabilities and Exposures (CVE):** Is Identifies vulnerabilities by name, number, and description. This makes the job of a penetration tester easier, as vendors, exploit developers, and others can use a common scheme to refer to vulnerabilities.